

TIB SYSTEMS LLC

SAP Security, GRC & Controls — Training Division

SAP Security, Controls & Compliance

An Entry-Level, No-Experience-Needed Introduction

Prepared for: Incoming Trainees / No Prior SAP Security Experience

Document Code: TIB-TRN-PREREQ-SAP-SECURITY-CONTROLS-002

Course Track: Prerequisite / Companion to the SAP Foundations Primer (TIB-TRN-PREREQ-SAP-FOUNDATIONS-001)

Version: 1.0

Issued: August 2026

WHO THIS GUIDE IS FOR

This guide picks up where the SAP Foundations Primer left off. There, you learned how SAP is built (client / application server / database) and how a transaction runs behind the scenes. Here, you will learn what SAP Security actually is, how to physically log in and navigate the system from your own laptop, and how the entire discipline of SAP controls auditing works end to end — from how a new employee gets access, to how an auditor tests it, to how a finding gets fixed.

How to Use This Guide

This is a hands-on companion to the SAP Foundations Primer. Where that guide built your mental model of SAP's architecture, this guide is deliberately more practical: it covers the actual screens you will click on, the actual keys you will press, and the actual end-to-end business processes — provisioning a user, and auditing that user's access — that make up the day-to-day work of SAP Security, Controls, and Compliance.

If a term here feels unfamiliar (application server, authorization object, T-code), it was covered in the Foundations Primer; a quick cross-reference is noted where it matters. You do not need to memorize every menu path on first read — you need to recognize the shape of each process well enough that, in your first weeks on a live engagement, none of it feels like it's happening in a foreign language.

What This Guide Covers

1. Part A — What SAP Security Is and How It Works (Chapters 1–3)
2. Part B — Hands-On: Logging In, Navigating, and Working in SAP (Chapters 4–9)
3. Part C — How Access Is Granted and Enforced, End to End (Chapters 10–11)
4. Part D — Why Controls Exist and How a Controls Audit Actually Runs (Chapters 12–13)
5. Part E — Glossary and Readiness Checklist (Chapters 14–15)

Chapter 1 — What Is SAP Security?

SAP Security is the set of configurations, processes, and controls that determine who can log into an SAP system, what they can see once they are in, and what they are allowed to do — display data, change data, approve a transaction, run a report, delete a record. It is not a single tool or a single screen; it is a discipline that spans technical configuration (roles and authorizations built inside SAP) and business process (how access gets requested, approved, granted, and reviewed).

It helps to separate SAP Security into three related but distinct questions, because people new to the field often blur them together:

Question	What It Means
Authentication	“Are you who you say you are?” — verified at logon, through a user ID and password, single sign-on, or multi-factor authentication.
Authorization	“Now that we know who you are, what are you allowed to do?” — enforced continuously, transaction by transaction, field by field, through roles and authorization objects.
Compliance / Controls	“Can we prove, after the fact, that access was appropriate, was properly approved, and was actually working as intended?” — this is the audit layer built on top of the first two.

SAP Security, Controls, and Compliance are really one continuous chain: security is designed and configured; controls are the rules that say what “good” security looks like for this company; and compliance/audit is the ongoing process of proving the two are actually aligned, day after day, for every user.

1.1 Why It Is Not Just “IT’s Problem”

Because SAP runs Finance, Procurement, HR, and Operations all in one connected system, a security gap is rarely just a technical issue — it is a business risk. A user with the ability to both create a vendor and approve payments to that vendor is a fraud risk. A user with unreviewed access to change their own pay rate in HR is a fraud risk. This is exactly why external and internal auditors test SAP Security as part of financial statement audits (SOX/ITGC), not just IT reviews.

Chapter 2 — How SAP Security Works

The mechanics of SAP Security are built directly on the architecture you learned in the Foundations Primer. As a quick refresher: every meaningful check happens on the application server, never trusted to the client, using the ABAP command `AUTHORITY-CHECK` against values stored in the user's security profile.

2.1 The Core Building Blocks

- A user (SU01) is a named account, linked to a real person, that can log on.

- A role (PFCG) is a container of permissions built for a job function — for example, “Accounts Payable Clerk.”
- Inside a role are authorization objects — named permission templates (for example, F_BKPF_BUK, which controls posting to a given company code) — each with specific field values (which company codes, which document types, display-only vs. change).
- A user is assigned one or more roles; the combination of every authorization object and value across all of a user's roles is that user's effective access.

2.2 The Logic in One Sentence

Access is never granted directly to a person; it is granted to a role, and the role is assigned to the person. This indirection is deliberate — it is what makes access manageable at scale (change the role once, and everyone with that role updates automatically) and what makes access auditable (you can always ask “what roles does this person have, and what does each role actually allow?”).

CROSS-REFERENCE

Chapters 4 and 7 of the SAP Foundations Primer walk through exactly where and how the AUTHORITY-CHECK statement executes during a live transaction. Chapter 11 of this guide revisits that same flow specifically from a security-testing point of view.

Chapter 3 — The Components of SAP Security

These are the building blocks you will hear referenced constantly, on every engagement. Learn to recognize each by name — the SOX/ITGC course will use these terms without re-defining them.

Component	What It Is
User (SU01)	An individual account: user ID, name, contact info, validity dates, user type (dialog, service, system, communication), and assigned roles.
Role (Single Role, PFCG)	A bundle of authorizations built around a specific job function or task, containing a menu (T-codes) and the authorization objects/values behind them.
Composite Role	A “role of roles” — a container that bundles several single roles together so they can be assigned to a user as one package.
Derived Role	A role that inherits its menu and authorization structure from a parent role, but with different organizational values (e.g., the same job function in a different company code or plant).
Authorization Object	A named permission template (e.g., F_BKPF_BUK) that defines which fields are checked and what values are allowed.
Authorization Field / Value	The specific data point inside an authorization object being checked (e.g., company code = 1000) and the value(s) permitted.
Profile	The technical, generated container of authorizations behind a role, assigned to the user automatically when the role is assigned (rarely built by hand today).

Component	What It Is
Segregation of Duties (SoD)	The principle — and the analysis — of ensuring no single person holds two conflicting capabilities (e.g., create vendor + pay vendor) that would let them commit and conceal fraud alone.
Sensitive / Critical Access	Powerful capabilities (mass data changes, direct table maintenance, developer access) that are not necessarily SoD conflicts on their own but carry elevated risk and require tighter control.

Chapter 4 — Accessing SAP From Your Windows Laptop

This chapter covers the literal, physical steps of getting from a blank Windows desktop into a working SAP session — the part every other chapter assumes you already know how to do.

4.1 The SAP GUI Client

To use classic SAP screens, your laptop needs the SAP GUI for Windows installed — a small client application (not a browser) provided by your IT/Basis team. Once installed, you will see an application called SAP Logon (or SAP Logon Pad) in your Windows Start Menu.

4.2 Connecting to a System

#	Where / Who	What Happens
1	Open SAP Logon	Launch the SAP Logon Pad from the Start Menu or desktop shortcut. You will see a list of pre-configured connection entries — one per SAP system your organization has set up for you (e.g., a Development, QA/Test, or Production system).
2	Select the correct entry	Double-click the system you need. Each entry already encodes the technical connection details (application server address, system number, routing) so you never type those yourself.
3	Enter your logon credentials	A logon screen appears asking for Client (a 3-digit number identifying the specific company/business unit inside that SAP system), your User ID, your Password, and Language.
4	Client is not optional	The client number matters enormously: the same SAP system can host multiple clients (e.g., a training client, a QA client, a production client), each with its own data. Logging into the wrong client is a common and consequential newcomer mistake.
5	Press Enter	If authentication succeeds, you land on the SAP Easy Access screen — covered in Chapter 5.

4.3 Accessing Fiori (Browser-Based) Apps

For newer, browser-based apps, you will instead be given a URL to your organization's Fiori Launchpad. You log in through your browser (often via single sign-on, so no separate password prompt), and you land on a tile-based home screen instead of the SAP GUI menu tree — the same underlying application server and security checks apply either way.

4.4 First-Time Setup Notes

- You may be required to change your password on first logon — this is standard and expected.
- If you cannot connect at all, the issue is almost always network/VPN access or an unconfigured connection entry — contact your Basis/IT team, not a security administrator, for connectivity issues.
- If you connect but get an authorization error immediately, that is a security/access issue — covered in Chapters 10–11.

Chapter 5 — Navigating Once You Are Logged In

After a successful logon (SAP GUI), you land on the SAP Easy Access screen. This is SAP's “home base” — everything else you do starts from here or from a screen you reached from here.

5.1 The Main Elements of the Screen

Element	What It Does
Command Field	The small entry box at the top-left, usually preceded by a small icon. This is where experienced users type a transaction code (T-code) directly to jump straight to a function, instead of clicking through menus.
Menu Tree (left pane)	A folder-style tree of everything available to you — organized by functional area (e.g., Accounting, Materials Management) or, more commonly for a specific job, by your role's own custom menu.
Favorites Folder	A personal folder at the top of the tree where you can drag-and-drop or add your most-used transactions for one-click access.
Menu Bar / Toolbar (top)	Standard drop-down menus (System, Edit, Favorites, Extras) and clickable icons — Save, Back, Exit, Print, Find — that behave consistently across almost every SAP screen.
Status Bar (bottom)	Shows system messages, the current transaction code, the system/client/user you are logged into, and response-time information — always worth a glance if something looks wrong.

5.2 Two Ways to Get Anywhere in SAP

1. Menu path — click through the folder tree (e.g., Accounting → Financial Accounting → General Ledger → Document Entry) until you reach the transaction you need.

2. T-code shortcut — type the transaction code directly into the command field and press Enter (e.g., typing FB50 takes you straight to Post General Journal Entry, skipping the menu entirely).

Experienced users almost always use T-codes directly once they know them; the menu tree exists mainly for discovery and for occasional or unfamiliar transactions.

5.3 Moving Backward and Exiting Cleanly

- Green back arrow (or F3) — go back one screen without saving.
- Green checkmark (Enter) — confirm/validate the current screen and proceed.
- Yellow door icon (Shift+F3) — exit the current transaction entirely, returning to Easy Access.
- Red “X” (F12 or Cancel) — cancel out of a screen, sometimes discarding unsaved input; use carefully.

Chapter 6 — The SAP Main Menu, at a High Level

The SAP Easy Access menu tree is organized by functional module — each folder representing a major business area SAP supports. You will not need all of these for any one job, but recognizing the module groupings helps you understand what kind of company function you are looking at whenever you see a T-code or a folder name.

Module (Folder)	What Lives There
FI — Financial Accounting	General ledger, accounts payable, accounts receivable, asset accounting, bank accounting — the core financial books of record.
CO — Controlling	Internal management accounting — cost centers, profit centers, internal orders, product costing.
MM — Materials Management	Purchasing, vendor management, inventory management, goods receipt.
SD — Sales and Distribution	Sales orders, pricing, billing, customer master data, shipping.
PP — Production Planning	Manufacturing planning, bills of material, production orders.
HCM / HR — Human Capital Management	Employee master data, payroll, time management, organizational structure.
BC — Basis / Technical	System administration, background jobs, technical configuration — largely outside end-user territory.
Tools / Administration	Where security-relevant transactions live: user maintenance (SU01), role maintenance (PFCG), audit and information tools (SUIM).

Note on personalized menus: many companies replace the generic SAP-delivered menu with a role-based menu — a simplified, custom folder tree built specifically around each job function, showing only the transactions that role actually needs. If your menu looks nothing like the standard modules above, this

is almost certainly why — and it is, itself, a security design choice, since a simpler menu reduces the chance of a user stumbling into a transaction they were never meant to use.

Chapter 7 — Logging Into More Than One SAP Screen at Once

It is extremely common — especially in security, controls, and audit work — to need two or more SAP windows open at once: one to look something up while keeping your original work in progress untouched, or to compare two transactions side by side.

7.1 Opening an Additional Session (Same System)

1. From any screen, go to the System menu (top menu bar) and select Create Session — or use the keyboard/command shortcut Ctrl+N.
2. A brand-new SAP window opens immediately, logged in as the same user, on the same system and client, starting at Easy Access.
3. By default, SAP allows up to six parallel sessions per logon (this limit is configurable by Basis); most users comfortably work with two or three.

7.2 Jumping to a New Transaction Without Losing Your Place

Command	What It Does
/n + T-code	Typed in the command field (e.g., /nFB50), this ends your current transaction in the same window and opens the new one — use when you are done with the current screen.
/o + T-code	Typed in the command field (e.g., /oFB50), this opens a brand-new session with the new transaction, leaving your current window exactly as it was — the fastest way to open a second session directly into a specific transaction.
/nend	Ends your SAP session entirely (logs you out of that window), prompting to save unsaved data first.
/nex	Exits SAP immediately without the usual prompts — use with caution.

7.3 Logging Into a Different System or Client Simultaneously

To work in two different SAP systems at once (for example, comparing configuration between a Test system and Production), simply open SAP Logon again and connect to the second system entry — this opens as a fully independent window, entirely separate from your other session(s), and you will log on (and can use a different client or user ID) separately for each.

Chapter 8 — Useful SAP Keyboard Shortcuts

SAP was built in an era before the mouse dominated business software, and many experienced users still work almost entirely from the keyboard because it is faster. These are the shortcuts worth learning early.

Shortcut	What It Does
Enter	Confirm/validate the current screen and continue.
F3	Back — return to the previous screen.
Shift+F3	Exit — leave the current transaction entirely.
F12 / Esc	Cancel the current screen or dialog.
Ctrl+S	Save.
Ctrl+P	Print.
Ctrl+N	Open a new session (Chapter 7).
Ctrl+F	Find / search within the current screen or list.
F8	Execute — run a report or query (very common in reporting transactions).
F4	Possible entries — opens a value-help dropdown/search for the field the cursor is in (extremely useful when you do not know a valid code).
Ctrl+Y	Select mode — lets you drag-select a block of text/columns in a report output, useful before copying.
Ctrl+C / Ctrl+V	Copy / paste, standard Windows behavior, works within most SAP fields and grids.
Shift+F4	Select all rows in many list/table displays.
Ctrl+Home / Ctrl+End	Jump to the very first / very last field or row on the screen.

TIP

The command field itself is the single highest-leverage shortcut in all of SAP: learning to type /n, /o, and a handful of T-codes from memory will make you faster than most users who rely on menu-clicking, within your first few weeks.

Chapter 9 — Exporting a Report to Excel

Almost every list or report screen in SAP — including the security and audit reports you will use constantly, like SUIM output — can be exported to Microsoft Excel for further analysis, sampling, or evidence documentation.

9.1 The Standard Method

#	Where / Who	What Happens
1	Run the report	Execute the transaction/report as normal so you are looking at the list output (an ALV grid — SAP's standard interactive list format).
2	Open the export menu	From the top menu bar, go to List → Export → Spreadsheet. (On some screens, a small “Export” icon in the toolbar directly above the list does the same thing.)
3	Confirm the format	SAP will prompt to confirm the file type (typically an .XLSX or a table format that opens natively in Excel); accept the default unless you have a specific reason not to.
4	Choose a save location	A standard Windows “Save As” dialog appears — choose a local folder or approved network location and confirm.
5	Open in Excel	Navigate to the saved file and open it normally; the data now behaves as a standard Excel worksheet, ready for filtering, pivoting, or attaching as audit evidence.

9.2 A Faster Alternative

On most ALV grid list screens, right-clicking anywhere inside the list also surfaces a context menu with an “Export” or “Spreadsheet” option that accomplishes the same result without going through the top menu.

9.3 Common Pitfalls

- Exporting before the list has fully loaded/executed can produce a blank or partial file — always confirm the on-screen list looks complete first.
- Some reports default to a summarized or filtered view; check that any on-screen filters reflect what you actually intend to export before you export it.
- For very large result sets, SAP may warn about performance or truncate results — narrow your selection criteria before execution rather than exporting an oversized, unfiltered list.

Chapter 10 — How Security Is Assigned to a New User, End to End

This is the full business process behind something that looks, from the outside, like a single click: “grant this person access.” In a well-controlled environment, it is a multi-step, multi-approver process with a documented trail at every stage — and that trail is exactly what a controls auditor later comes back to test.

#	Where / Who	What Happens
1	Trigger	A new hire, transfer, or role change is initiated — typically flowing from an HR system (new employee record, new position, or

#	Where / Who	What Happens
		organizational change) or a formal manager request.
2	Access determination	Someone — typically the hiring manager, sometimes supported by a role-mapping catalog — determines which SAP role(s) match the person's new job function. Well-run organizations maintain a pre-approved “role catalog” mapped to job titles specifically to keep this consistent and reduce ad hoc requests.
3	Formal access request	The request is logged in a tracked system — an access-request/GRC tool, a ticketing system, or at minimum a documented email/form — identifying exactly who is requesting what access, for whom, and why.
4	Segregation-of-duties (SoD) check	Before approval, the requested access is checked against the organization's SoD rule set to confirm it does not create a conflict with any access the person already has (e.g., adding “approve payment” for someone who already has “create vendor”). If a conflict is found, it is either rejected, escalated for a documented business-justified exception, or paired with a compensating/mitigating control.
5	Approval	An appropriate approver — typically the requestor's manager and/or the data/role owner — formally approves the request. This approval, and who gave it, is itself a critical piece of audit evidence.
6	Technical provisioning	A security administrator executes the approved request in SAP: creating the user account (SU01) if new, and assigning the approved role(s) via PFCG (or an automated provisioning/GRC tool that performs the same action under the hood).

#	Where / Who	What Happens
7	Validation / testing	The new access is confirmed to work as intended — often via a quick test login or a review of the assigned roles against the original request — before being considered complete.
8	Documentation and evidence retention	Every step above — the request, the SoD check result, the approval, and the technical action — is retained as evidence, because this exact trail is what an auditor will sample and test later (Chapter 13).
9	Periodic (ongoing) review	Access is not a one-time event. On a recurring cycle (commonly quarterly or semi-annually), managers or data owners formally re-certify that each user's access is still appropriate; access that is no longer needed is identified and removed.
10	Termination / transfer trigger	When someone leaves the company or changes roles, a corresponding process removes or adjusts access — timely deprovisioning is one of the most heavily tested ITGC controls, because stale access left behind after departure is a classic audit finding.
WHY THIS WHOLE CHAIN MATTERS An auditor testing “new user access” is really testing whether every one of these steps happened, in order, with proper approval, for a sample of actual new hires — not just whether the final role assignment in SAP looks correct today.		

Chapter 11 — How Security Logic Flows From Login to Executing an Application

This chapter connects the dots between what you learned in the Foundations Primer (the technical, screen-by-screen mechanics) and what you just read in Chapter 10 (the business process that put that access there in the first place). Here is the security-specific view of that same flow, from the moment of login to the moment a specific action either succeeds or is blocked.

#	Where / Who	What Happens
1	Authentication at logon	The user's ID and password (or SSO credential) are validated by the application server. If this fails, nothing downstream is even reached.
2	Authorization profile loaded into the session	Immediately upon successful logon, the application server loads the user's complete set of assigned roles — and every authorization object and value inside them — into that session's memory. This loaded profile is what every subsequent check is measured against, for the life of the session.
3	Menu/T-code access check (S_TCODE)	When the user attempts to open any transaction — by menu click or by typing a T-code — the system checks the authorization object S_TCODE to confirm the loaded profile includes the right to start that specific transaction at all.
4	Screen-level and field-level checks	As the transaction proceeds, the underlying ABAP program runs further AUTHORITY-CHECK statements against other relevant authorization objects — for example, checking whether the user's profile allows the specific company code, plant, document type, or action (create vs. display vs. change) being attempted on this particular screen.
5	Pass — action proceeds	If every required check passes, the program continues normally: data is displayed, calculated, or — if the user submits a save — ultimately written to the database, exactly as traced in Chapter 7 of the Foundations Primer.
6	Fail — action is blocked	If any required check fails, the program stops at that point, returns an authorization-error message identifying the missing authorization (useful both to the user and, later, to whoever troubleshoots the access request), and nothing is saved.
7	Every single time, no exceptions by default	Critically, this is not a one-time gate checked only at logon — it is re-evaluated on essentially every relevant action, every time, for the entire session. A user's access can change mid-day (e.g., a role is removed), and the very next action they attempt will reflect that change.

This is the mechanical reality behind every access decision you will ever review as an auditor: somewhere in this chain, on a specific screen, against a specific authorization object, the system either let a specific person do a specific thing, or it did not — and your job in a controls review is to confirm that outcome matches what should have been approved back in Chapter 10.

Chapter 12 — Why SAP Control Is Needed: What It Really Means and Does

“Control,” in this context, is a specific, technical word — not a vague synonym for “security.” A control is a defined activity, automated or manual, designed to prevent or detect a specific risk from materializing. SAP controls are the subset of those activities that live inside, or depend on, the SAP system.

12.1 Two Basic Types of Control

Type	What It Does
Preventive Control	Stops an unwanted outcome from happening in the first place — for example, an authorization design that makes it technically impossible for one person to both create and approve the same purchase order.
Detective Control	Identifies an unwanted outcome after the fact, so it can be investigated and corrected — for example, a periodic review of all journal entries posted by users outside the Finance department.

12.2 Two Basic Categories, by Where They Live

Category	What It Covers
ITGC (IT General Controls)	Controls over the SAP environment itself — who can get access at all, how changes to the system are managed, how the system's own logs and backups are protected. This is the layer covered in Chapters 10–11 of this guide.
Application / Process Controls	Controls built into specific business processes running on top of that environment — a three-way match before a vendor is paid, an approval workflow before a journal entry posts above a threshold.

12.3 Why This Actually Matters — Not Just as a Compliance Exercise

A publicly traded company's financial statements are only as trustworthy as the systems and processes that produced the numbers in them. SAP controls exist because regulators (and a company's own board and management) need a defensible answer to a simple question: “how do you know the numbers are right, and how do you know no one could manipulate them without being caught?” Section 404 of the U.S. Sarbanes-Oxley Act (SOX) is the most common driver of this requirement for U.S.-listed companies, but the underlying logic — access should match job need, changes should be controlled, and both should be provable — applies universally, everywhere SAP is trusted to run a real business.

In short: SAP control is the evidence that the powerful, automated, interconnected system you learned about in the Foundations Primer is not, in practice, a bigger and faster way to make an undetected mistake or commit an undetected fraud.

Chapter 13 — The SAP Controls Audit Process, End to End

This chapter walks the full lifecycle of a controls audit — from planning through to a closed, remediated finding — so that when you join a live engagement, you can place whatever task you are given into the bigger picture.

#	Where / Who	What Happens
1	Planning and scoping	The audit team identifies which SAP systems, processes, and time period are in scope, and which specific controls (from a

#	Where / Who	What Happens
		control matrix — often mapped to financial statement risks) will be tested.
2	Walkthrough	For each control, the auditor meets with the process/control owner to understand, step by step, how the control is actually supposed to operate — who does what, using which SAP transaction, on what frequency — and documents that understanding.
3	Evidence identification	The auditor determines what SAP-generated evidence would prove the control operated as described — for example, a SUIM report of role assignments as of a point in time, a PFCG role's authorization detail, a change log (CDHDR/CDPOS) extract, or an approval workflow record.
4	Sample selection	Rather than testing every single transaction or user (rarely practical), the auditor selects a representative sample — for example, a sample of new hires from the period, or a sample of journal entries above a threshold — following a defined sampling methodology.
5	Evidence gathering from SAP screens	The auditor (or the client, on request) pulls the actual evidence directly from SAP — running the relevant T-codes (e.g., SUIM for user/role information, SE16/SE16N for table displays, PFCG for role detail), and exporting the results

#	Where / Who	What Happens
		(Chapter 9) for documentation.
6	Testing	The auditor compares what the evidence shows against what the control was supposed to guarantee — for example, confirming that each sampled new hire's access matches an approved, documented request with no unresolved SoD conflict.
7	Exception identification	Any sample item that does not match expectations — a missing approval, an SoD conflict without a documented mitigating control, access granted before approval was received — is logged as an exception.
8	Root cause analysis	For each exception, the auditor and the process owner work to understand why it happened — a one-off human error, or a systemic gap in the process or system configuration — because the fix should match the actual cause.
9	Reporting	Findings are formally documented — typically including the control tested, the exception(s) found, the risk they represent, and the root cause — and communicated to management and, where applicable, to the external auditor.
10	Management response	Process owners formally respond to each finding, typically committing to a specific remediation action and a target completion date.

#	Where / Who	What Happens
11	Mitigation / remediation	The underlying issue is fixed — this might mean removing inappropriate access, tightening a role's authorizations, implementing a new approval step, or introducing a compensating control (e.g., a monthly review) where full prevention is not immediately feasible.
12	Control redesign (where needed)	If the root cause was systemic — the control itself was poorly designed, not just poorly executed — the control is redesigned: a role is rebuilt, a workflow is restructured, an automated SoD check is added going forward, rather than simply fixing the one exception found.
13	Retest / validation	In a later period (or immediately, for a redesigned control), the auditor retests to confirm the fix actually closed the gap — a finding is not considered resolved until this step confirms it.
THE THROUGH-LINE Every step above ultimately traces back to concepts already in this guide: the users, roles, and authorization objects of Chapters 2–3; the provisioning process of Chapter 10; the login-to-execution logic of Chapter 11; and the navigation and export skills of Chapters 4–9 that let you actually go pull the evidence yourself. This is not a separate body of knowledge — it is everything you have just learned, applied to a single recurring question: can we prove this worked?		

Chapter 14 — Glossary of Terms

Term	Plain-English Meaning
Authentication	Verifying a user's identity at logon (user ID + password, SSO, or MFA).
Authorization	The ongoing check of what an authenticated user is allowed to do.
Authorization Object	A named permission template (e.g., F_BKPF_BUK) checked via AUTHORITY-CHECK.
Client	A 3-digit number identifying a distinct business/data area within one SAP system (e.g., Production vs. Test).
Composite Role	A container bundling several single roles for assignment as one unit.
Derived Role	A role inheriting structure from a parent role with different organizational values.
Fiori Launchpad	SAP's browser-based, tile-driven entry point for modern apps.
ITGC	IT General Controls — controls over the IT environment itself (access, change management, operations).
PFCG	The T-code for maintaining roles — SAP's Role Maintenance transaction.
Provisioning	The end-to-end process of granting a user access, from request through technical assignment.
Role	A bundle of menu and authorization content built around a job function, assigned to users.
Root Cause Analysis	Determining the underlying reason an exception occurred, to target remediation correctly.
SAP Easy Access	The default home screen shown after SAP GUI logon.
SAP Logon Pad	The Windows client application used to connect to SAP systems.
Segregation of Duties (SoD)	Ensuring no individual holds conflicting capabilities that would let them commit and conceal fraud alone.
Session	An individual open SAP window; multiple sessions can run in parallel for one logged-in user.
SU01	The T-code for maintaining individual user accounts.
SUIM	The T-code for the User Information System — SAP's built-in security reporting toolkit.
T-code (Transaction Code)	A short code that acts as a direct pointer to a specific SAP function.
Walkthrough	An auditor's initial step-by-step review of how a control is supposed to operate, with the control owner.

Chapter 15 — Pre-Course Readiness Checklist

Before your first live session on SAP Security, Controls & Compliance, confirm you can do each of the following. If any item feels shaky, re-read the referenced chapter.

- I can explain the difference between authentication, authorization, and compliance/controls. (Ch. 1)
- I can explain, in plain language, how a user, a role, and an authorization object relate to each other. (Ch. 2–3)
- I can log into SAP GUI from a Windows laptop, including selecting the correct system and client. (Ch. 4)
- I can navigate using both the menu tree and the command field, and I know how to move back and exit cleanly. (Ch. 5)
- I can name at least four SAP functional modules and what each generally covers. (Ch. 6)
- I can open a second SAP session and explain the difference between /n and /o. (Ch. 7)
- I am comfortable with at least eight keyboard shortcuts from Chapter 8 without looking them up.
- I can export a report to Excel from an SAP list screen. (Ch. 9)
- I can describe, step by step, the full end-to-end process of granting a new user access. (Ch. 10)
- I can describe how a single access check actually executes, from login to a pass/fail decision on one screen. (Ch. 11)
- I can explain, in my own words, why SAP controls exist and the difference between preventive and detective controls. (Ch. 12)
- I can walk through the full controls audit lifecycle, from planning through retest, in my own words. (Ch. 13)

READY TO BEGIN

Once every box above is checked honestly, you have both the conceptual grounding and the practical, hands-on footing this course track assumes. Proceed to your live SAP Security, Controls & Compliance coursework.